AUDITORÍA DE SEGURIDAD · WORDPRESS

Informe ejecutivo de seguridad

http://127.0.0.1:8099

Cliente	Auditor	Fecha	Perfil
Empresa Demo S.A.S.	**Datos simulados**	**05/11/2026 12:38**	**quick**

CONFIDENCIAL

Riesgo crítico

Exposición grave; se requiere acción inmediata.

Índice de riesgo: 82/100. A mayor valor, mayor exposición.

1	3	4	11
Crítica	Alta	Media	Baja

La revisión de seguridad de 127.0.0.1 identificó 19 hallazgos: 1 crítica, 3 altas, 4 medias, 11 bajas. Existen debilidades de prioridad alta o crítica que conviene corregir de inmediato, ya que podrían ser aprovechadas por atacantes para comprometer el sitio o la información de sus usuarios.

Evaluación parcial. La calificación solo refleja lo que se pudo comprobar. No se evaluó por completo: Versiones (api.wordpress.org), Vulnerabilidades conocidas (CVE). El detalle está en el informe técnico.

Lo más urgente

Los riesgos con mayor impacto y la acción recomendada para cada uno.

1

Crítica WPA-001

Copia de wp-config.php accesible públicamente

Compromiso total: acceso a la base de datos, posible toma de control del sitio y de los datos de usuarios.

Qué hacer: Retire el archivo del directorio web, rote TODAS las credenciales afectadas y revise los registros de acceso por descargas previas. Cambie las salts/keys de wp-config.php y la contraseña de la base de datos.

2

Alta WPA-002

Registro de depuración de WordPress accesible

Información valiosa para preparar ataques dirigidos.

Qué hacer: Elimine el archivo, desactive WP_DEBUG_LOG en producción o redirija el log fuera del directorio web.

3

Alta WPA-003

PHP 7.4 está fuera de soporte

Vulnerabilidades conocidas del lenguaje quedan sin corregir y pueden comprometer todo el servidor.

Qué hacer: Migre a una rama de PHP con soporte activo (consulte php.net/supported-versions) tras probar tema y plugins en un entorno de pruebas.

4

Alta WPA-004

El sitio se sirve sin HTTPS

Un atacante en la misma red (Wi-Fi público, proveedor) podría robar sesiones de administrador o inyectar contenido malicioso a sus visitantes.

Qué hacer: Instale un certificado TLS (p. ej. Let's Encrypt), redirija todo el tráfico HTTP a HTTPS y actualice las URLs de WordPress (Ajustes → Generales) a https://.

5

Media WPA-005

Registro público de usuarios habilitado

Aumenta la probabilidad o el impacto de un ataque cuando se combina con otras debilidades.

Qué hacer: Desactive 'Cualquiera puede registrarse' (Ajustes → Generales) si no lo necesita; si lo necesita, mantenga el rol por defecto como Suscriptor y añada CAPTCHA/verificación de email.

Plan de acción

Dentro de cada plazo, primero el mayor riesgo y luego lo que requiere menos esfuerzo.

Acciones inmediatas

0 a 7 días (riesgo crítico y alto)

- [ ] Copia de wp-config.php accesible públicamente
  WPA-001 · Esfuerzo bajo
- [ ] Registro de depuración de WordPress accesible
  WPA-002 · Esfuerzo bajo
- [ ] El sitio se sirve sin HTTPS
  WPA-004 · Esfuerzo bajo
- [ ] PHP 7.4 está fuera de soporte
  WPA-003 · Esfuerzo medio

Corto plazo

hasta 30 días (riesgo medio)

- [ ] Registro público de usuarios habilitado
  WPA-005 · Esfuerzo bajo
- [ ] Enumeración de nombres de usuario posible
  WPA-006 · Esfuerzo bajo
- [ ] Listado de directorios habilitado
  WPA-007 · Esfuerzo bajo
- [ ] XML-RPC habilitado con métodos de riesgo
  WPA-008 · Esfuerzo bajo

Mejora continua

hasta 90 días (riesgo bajo e informativo)

- [ ] Panel de acceso (wp-login.php) expuesto a Internet
  WPA-009 · Esfuerzo bajo
- [ ] Existen nombres de usuario predecibles
  WPA-010 · Esfuerzo bajo
- [ ] Cabeceras de seguridad HTTP recomendadas ausentes
  WPA-011 · Esfuerzo bajo
- [ ] La REST API refleja el Origin y permite credenciales (comportamiento estándar de WordPress)
  WPA-013 · Esfuerzo bajo
- [ ] Métodos HTTP innecesarios habilitados
  WPA-014 · Esfuerzo bajo
- [ ] El servidor divulga versiones de software
  WPA-015 · Esfuerzo bajo

- [ ] Los readme.txt de los plugins son accesibles públicamente
  WPA-016 · Esfuerzo bajo
- [ ] La versión de WordPress es visible públicamente
  WPA-017 · Esfuerzo bajo
- [ ] Cookies sin atributos de seguridad
  WPA-018 · Esfuerzo bajo
- [ ] wp-cron.php accesible públicamente
  WPA-019 · Esfuerzo bajo
- [ ] Scripts de terceros sin Subresource Integrity (SRI)
  WPA-012 · Esfuerzo medio
- [ ] No existe security.txt
  WPA-020 · Esfuerzo bajo

Lo que está bien

Las pruebas automatizadas no confirmaron controles destacables.

Alcance

Se evaluó la exposición pública de **http://127.0.0.1:8099** con pruebas no intrusivas: sin fuerza bruta, sin explotación y sin modificar contenido. No se evaluó el código a medida, los procesos internos ni la resistencia a ataques de contraseñas. Se recomienda complementar con una revisión manual y repetir la auditoría después de corregir.

Generado por wpaudit 1.2.0 el 05/11/2026 12:38. La ausencia de hallazgos no garantiza la ausencia de vulnerabilidades.